Course Code: ITA1439 **Course Name:** Ethical Hacking **Slot:** A

Assignment: CO1 – Assignment 1 (Individual, Duration 1 Week, Total 50 Marks)

Student Name: Sayed Fazal **Register No.:** 192311291

Course Outcome – CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Title: Design and develop a complete ethical-hacking engagement framework for a university's authorized security-assessment programme.

Scenario Summary

A university is establishing an **Authorized Security-Assessment Programme** to test its student portal, learning-management system (LMS), email service and campus network before a major upgrade. The programme initially covers about **20 systems and 50 staff**, but the framework must scale to the whole university and later admit **external third-party assessors**. Tests may be requested by different departments and may touch systems holding personal data. The risk of an unstructured approach is unauthorized access, legal exposure, damage to live systems, unclear scope and uncoordinated disclosure. Acting as the **Ethical-Hacking Governance Team**, this report designs a complete, reusable engagement framework. **No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.**

The framework keeps three ideas distinct throughout: what is **authorized** (permitted by the asset owner), what is **legal** (permitted by law), and what is **appropriate** (suitable for a university that holds student data).

Task 1 – Enquiry and Framework Blueprint (4 Marks)

1.1 Scenario converted into governance requirements

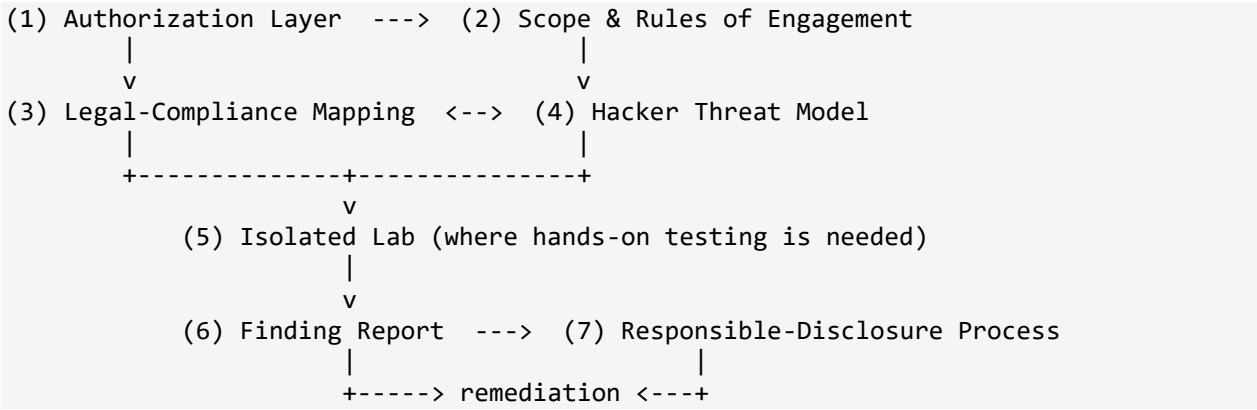
#	Requirement	Derived from scenario
R1	Every test must have provable written authorization from the asset owner	Risk of unauthorized access

#	Requirement	Derived from scenario
R2	Scope and rules of engagement must be fixed before testing	Unclear scope
R3	Engagements must comply with IT Act 2000 and data-protection law	Legal exposure; personal data
R4	Live systems must be protected; risky testing moved to an isolated lab	Damage to live systems
R5	Findings must be disclosed through one coordinated process	Uncoordinated disclosure
R6	The framework must scale from 20 to all systems and admit external testers	Expected growth
R7	Roles and approvals must be recorded and auditable	Multiple departments and testers

Systems in scope (initial): student portal, LMS, email service, campus network — ~20 systems. **Stakeholders:** university management (programme owner), system/asset owners, internal testers, future external assessors, IT operations, legal/data-protection officer, and the affected users. **Expected activities:** request, authorization, scoping, threat modelling, lab-based testing, reporting, coordinated disclosure, remediation tracking. **Constraints:** no live exploitation, no access to personal data beyond proof, fixed testing windows, legal compliance, limited budget and staff.

1.2 Framework blueprint – how the components cooperate

The framework has seven cooperating components. The arrows show the normal flow of one engagement; each component feeds the next and several feed back.



- **Authorization** gates everything: no sign-off, no engagement.
- **Scope/RoE** defines what the authorization actually permits.
- **Legal mapping** and the **threat model** constrain and inform scope (which laws apply, which attackers are modelled).
- The **isolated lab** contains any hands-on testing.
- The **finding report** produces a structured output that drives **responsible disclosure** and remediation.

1.3 Enquiry questions the framework must answer

1. **Who authorizes a test, and how is that authorization proven and recorded?**
2. **What is in scope and out of scope, and how is an out-of-scope request detected?**
3. **Which laws apply, especially when a system holds student personal data?**
4. **How are discovered vulnerabilities disclosed, to whom, and within what timeline?**
5. **How is live-system damage prevented when hands-on testing is required?** (added for completeness)

1.4 Design criteria (used as acceptance criteria)

#	Design criterion	Acceptance test for the final framework
C1	**Authorized**	No engagement can start without recorded written sign-off
C2	**Legal**	Every activity maps to a permitted provision of the IT Act / CFAA
C3	**Safe**	Risky testing is contained in the isolated lab; live systems protected
C4	**Traceable**	Every approval, finding and disclosure is logged and auditable
C5	**Scalable**	The same framework works for 1 department or the whole university with external testers
C6	**Coordinated**	All findings follow one disclosure process with defined timelines

Rationale: these requirements, enquiry questions and criteria turn the scenario's stated fears (unauthorized access, legal exposure, damage, unclear scope, uncoordinated disclosure) into concrete, testable targets that Tasks 2–11 must satisfy. The final framework is judged against C1–C6 in Task 9.

Task 2 – Hacker Threat Model and Classification (4 Marks)

2.1 Classification criteria

An actor is classified consistently using four attributes:

- **Authorization** – does the actor have permission? (Yes / No)
- **Intent** – protect, profit, disrupt, curiosity, ideology.
- **Origin** – internal (insider) or external.
- **Capability** – low / medium / high skill and resources.

Naming rule: classify first by *authorization*, then by *intent*. (Authorized + protective = white-hat; unauthorized + malicious = black-hat; unauthorized + mixed/good intent = grey-hat.) This order keeps classification repeatable.

2.2 Hacker types mapped to motivation, capability and likely university targets

Type	Authorization	Motivation	Typical capability	Likely university target
White-hat	Yes	Improve security	Medium–High	Any in-scope system (as tester)
Black-hat	No	Profit, theft, damage	Medium–High	Student records, email, finance
Grey-hat	No	Curiosity, often discloses	Medium	Public portal, LMS
Script kiddie	No	Mischief, status	Low (uses others' tools)	Public websites, Wi-Fi
Hacktivist	No	Political/social cause	Low–Medium	Public site defacement, leaks
Insider	(Mis)uses granted access	Grievance, profit	Low–Medium	Internal systems, grades, HR data
State-sponsored	No	Espionage, strategic	High	Research data, named individuals

2.3 Borderline actor – two classifications, then a justified choice

Actor: a student with a legitimate portal login who uses a URL flaw to view another student's marks, then emails the administration about it.

- **Classification A – Insider.** The student has authorized access to the portal and used that position, so they could be modelled as a malicious or curious insider.
- **Classification B – Grey-hat.** The student had **no authorization to test**, acted on curiosity, caused no lasting harm and **disclosed responsibly** — the grey-hat pattern.

Rejected alternative: Insider is rejected because "insider" in this model means misuse of *granted* access for the actor's own benefit; here the access granted was only to the student's *own* marks, the testing was unauthorized, and the disclosure was protective, not self-serving.

Final classification: Grey-hat (leaning white). Justification: applying the naming rule — authorization first (none for testing), then intent (good, with responsible disclosure) — lands on grey-hat. This matters for response: a grey-hat good-faith reporter should be handled through the disclosure process (Task 6), not treated as a malicious insider.

2.4 Evidence

The deliverable for this task is the **criteria (2.1)**, the **mapping table (2.2)**, the **two rejected/accepted classifications (2.3)** and the justified final choice — together a reusable threat model that Tasks 5 and 6 reference when deciding how to treat a reported finding.

Task 3 – Ethics and Code-of-Conduct Module (4 Marks)

3.1 Ethical principles governing an authorized engagement

#	Principle	Meaning in this programme
P1	Written authorization	No action without recorded sign-off from the asset owner
P2	Agreed scope	Act only within the systems and techniques in the RoE
P3	Confidentiality	Findings and any data seen are kept secret and shared only with authorised parties
P4	Integrity	Do not alter, plant or destroy data; preserve evidence
P5	Avoid harm (non-maleficence)	Protect availability of live systems and privacy of users
P6	Data minimisation	Access the least data needed to prove a finding; never copy personal data
P7	Honest reporting	Report all findings truthfully, with no exaggeration or concealment

3.2 Decision rules to detect or prevent unethical actions

The module encodes simple IF–THEN checks that can be applied during an engagement:

1. **IF** no signed authorization exists for the target **THEN** stop (violates P1).
2. **IF** the action targets a system not in the RoE **THEN** stop and escalate (violates P2).
3. **IF** the action would read or copy personal data beyond proof **THEN** stop (violates P6).
4. **IF** the action would modify or delete data on a live system **THEN** stop (violates P4/P5).
5. **IF** a finding is being hidden, downplayed or sold **THEN** flag misconduct (violates P7).

3.3 Scenario test cases (acceptable / borderline / unacceptable)

Case	Action	Code-of-conduct response	Verdict
A	Tester finds an SQL-injection flaw, records only the proof, reports it	Passes all rules; honest reporting	**Acceptable**
B	Tester discovers a flaw on a system *adjacent to* but not in the RoE	Rule 2 triggers: stop, document, request scope amendment	**Borderline** – allowed only after written scope change
C	Tester downloads a table of student records "to show impact"	Rule 3 triggers: data beyond proof	**Unacceptable**
D	Tester keeps a copy of exploit code and	Rules 3 & 5: retention and	**Unacceptable**

Case	Action	Code-of-conduct response	Verdict
	credentials "for later"	concealment	
E	Tester is offered money by a third party to leak findings	Rule 5: misconduct	**Unacceptable**

The three verdict levels show the rules cleanly separate acceptable from unacceptable actions, with the borderline case resolved by a defined route (scope amendment) rather than tester discretion.

3.4 How the module preserves trust, legality and professionalism

By binding every action to authorization, scope and honesty, the module ensures the university can trust testers with sensitive systems, keeps the engagement inside the law (Task 4), and makes behaviour auditable. It is **reusable**: the same principles and rules apply whether the tester is internal or an external third party, which directly supports the scalability criterion C5.

Task 4 – Legal-Compliance Mapping (4 Marks)

4.1 Offences, obligations and penalties – IT Act 2000 vs CFAA

Provision	Law	What it covers	Penalty (indicative)
Section 43	IT Act 2000 (India)	Unauthorized access, downloading, damage to a computer/system	Civil liability – compensation to the affected party
Section 66	IT Act 2000	Section 43 acts done dishonestly or fraudulently	Up to 3 years imprisonment and/or fine up to ₹5 lakh
Section 66C	IT Act 2000	Identity theft (misuse of passwords, credentials)	Up to 3 years and fine up to ₹1 lakh
Section 66D	IT Act 2000	Cheating by personation using a computer	Up to 3 years and fine up to ₹1 lakh
Section 72	IT Act 2000	Breach of confidentiality and privacy	Up to 2 years and/or fine
DPDP Act 2023	India	Obligations for processing personal data	Significant financial penalties for breach
18 U.S.C. §1030	CFAA (USA)	Access "without authorization" or "exceeding authorized access"	Fines and imprisonment, severity-based

Comparison: both laws make **authorization the dividing line**. The IT Act separates civil (S.43) from criminal (S.66) liability depending on dishonest intent, while the CFAA's key phrase "exceeding

authorized access" closely mirrors the scenario's risk of a tester drifting out of scope. The practical lesson is identical: unauthorized or out-of-scope access is an offence regardless of the tester's good intentions.

4.2 Each legal requirement linked to a framework control

Legal requirement	Framework control that satisfies it
Access must be authorized (S.43 / CFAA)	Authorization Layer – recorded written sign-off (Task 6)
Must not exceed authorized scope (CFAA)	Scope & RoE document + out-of-scope detection (Task 5)
No dishonest access or identity misuse (S.66, 66C/D)	Code of conduct rules 1–5 (Task 3)
Confidentiality of data (S.72)	Confidentiality principle P3 + data minimisation P6 (Task 3)
Personal-data protection (DPDP 2023)	No-copy-of-personal-data rule; lab testing on dummy data (Task 7)
Evidence integrity	Integrity principle P4 + finding-report logging (Task 8)

4.3 Which laws apply when a test touches personal data – decision and justification

Decision: when an in-scope system (e.g. the student portal) holds personal data, the engagement must comply with **both** the IT Act 2000 (S.43, 66, 72) **and** the DPDP Act 2023; the CFAA is used as a comparative benchmark, not as binding Indian law.

Justification: the student portal and email service hold student personal data, so the DPDP Act's processing obligations are engaged the moment a tester could view that data. The controls above (data minimisation, no copying, lab testing on synthetic data, confidentiality) are therefore **mandatory, not optional**, for those systems. For a purely technical system holding no personal data (e.g. an isolated network device), the IT Act access provisions still apply but the DPDP obligations do not. This is the framework's rule for deciding the applicable legal regime per system.

Task 5 – Scope and Rules-of-Engagement (RoE) Document (4 Marks)

5.1 RoE document structure

Section	Content
Engagement ID	Unique reference, e.g. `ENG-2026-014`
Authorization reference	Signed-form ID + approver name and date

Section	Content
In-scope systems	Explicit list with hostnames/IPs, e.g. `portal.univ.edu`, `lms.univ.edu`
Out-of-scope systems	Everything not listed; named exclusions (e.g. production finance DB, third-party cloud)
Testing window	Allowed dates/hours, e.g. 22:00–06:00 on named dates
Permitted techniques	Passive recon, authenticated scanning, lab-based exploitation on copies
Prohibited techniques	DoS on live systems, social engineering of real staff, copying personal data, physical intrusion
Escalation path	Named contacts: engagement lead → asset owner → CISO; 24×7 emergency number
Data handling	Minimisation, encryption of findings, retention/disposal

5.2 Authorization-verification rules

1. Each engagement must cite a **signed authorization form** (Task 8) by ID.
2. The approver must be the **asset owner or their delegate**, verified against an owners register.
3. The RoE is **invalid** until the authorization reference is present and the approver confirmed.
4. Any scope change requires a **new signed amendment**; verbal changes are not accepted.

5.3 Scope boundaries – detecting an out-of-scope request

Rule: a target is in scope **only if** its hostname/IP appears in the in-scope list **and** the current time falls in the testing window **and** the technique is on the permitted list. If any condition fails, the request is **out of scope** and must stop and escalate.

Example detection: a request to test `research-db.univ.edu` is checked against the in-scope list `{portal, lms, email, campus-net}` → not present → **out of scope** → escalate for a scope amendment before any action.

5.4 Derived pre-engagement checklist (transformation of the RoE)

The RoE transforms into a yes/no checklist the lead completes before any testing begins:

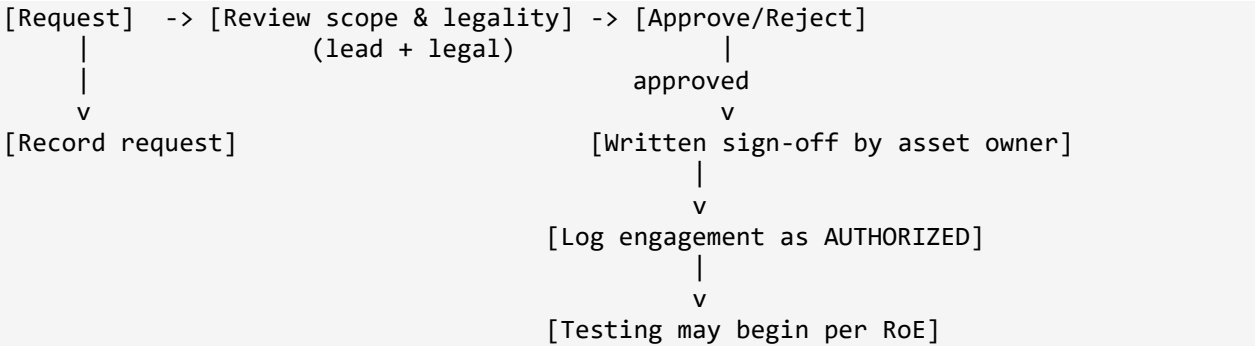
- ☐ Signed authorization form on file and ID recorded?
- ☐ Approver confirmed as asset owner/delegate?
- ☐ In-scope systems listed with hostnames/IPs?
- ☐ Out-of-scope exclusions stated?
- ☐ Testing window agreed and current?
- ☐ Permitted and prohibited techniques fixed?
- ☐ Personal-data systems flagged and handling rules set?

- ☐ Escalation contacts and emergency number recorded?
- ☐ Isolated lab prepared where hands-on testing is needed?

All boxes must be ticked; any "no" blocks the engagement. This checklist is the operational gate that links the RoE to the authorization layer in Task 6.

Task 6 – Authorization and Disclosure Layer (5 Marks)

6.1 Authorization workflow



Each step is recorded with a timestamp, the actor and the decision. An engagement cannot move to testing until its status is logged **AUTHORIZED** with a sign-off reference.

6.2 Responsible (coordinated) disclosure process

Reporting format: each finding is reported using the structured Finding Report (Task 8) containing ID, severity (CVSS), affected system, evidence and recommended fix.

Timeline / remediation window (default):

Severity	Acknowledge	Remediation window	Disclosure
Critical	24 hours	7 days	After fix or by agreement
High	48 hours	15 days	After fix or by agreement
Medium	5 days	30 days	After fix
Low	5 days	90 days	After fix

Comparison of disclosure models:

Model	How it works	Suitability for the university
Coordinated (responsible)	Report privately, fix within window, then disclose	**Chosen** – protects students, controlled
Full disclosure	Public release immediately	Rejected – exposes users before a fix
Bug bounty	Open programme pays external researchers	Future option once the programme matures and admits external testers

6.3 Logging and decision operations

- **log_approval(engagement_id, approver, timestamp, signoff_ref)** – records authorization.
- **update_status(engagement_id, status)** – status moves REQUESTED → AUTHORIZED → TESTING → REPORTED → CLOSED.
- **can_disclose(finding)** – returns **true** only if the remediation window has passed **or** the asset owner has signed off on early disclosure.

6.4 Rules for choosing coordinated vs full disclosure

1. **Default to coordinated** for every finding.
2. Use **full disclosure only if** the vendor/owner is unresponsive past the window **and** users remain at active risk **and** the CISO approves — and even then publish mitigations, not exploit code.
3. Findings on systems holding personal data are **never** fully disclosed with technical detail before a fix (links to DPDP obligations, Task 4).

6.5 Interaction with other components

- **With RoE (Task 5):** disclosure only proceeds for findings produced inside an authorized, in-scope engagement — `can_disclose` checks the engagement is AUTHORIZED.
- **With legal mapping (Task 4):** the "never fully disclose personal-data findings pre-fix" rule enforces the DPDP/S.72 controls.
- **With the document library (Task 8):** the structured Finding Report is the input to `can_disclose` and the disclosure timeline.

This makes the authorization–disclosure layer the hub that ties scope, law and reporting together rather than a standalone rule.

Task 7 – Isolated Ethical-Hacking Lab (5 Marks)

7.1 Lab design and components

The lab is a self-contained virtual network on a **host-only** segment `192.168.56.0/24`, with no route to the internet or the university production network.

Component	Role	IP (reserved)
Kali Linux VM	Attacker / tester workstation	`192.168.56.10`
Target VM 1 (Metasploitable / DVWA)	Vulnerable web app (portal/LMS stand-in)	`192.168.56.20`
Target VM 2 (Linux server)	Network/service target	`192.168.56.30`
Host-only adapter (vboxnet0)	Isolated virtual switch	gateway `192.168.56.1`

Connectivity: all VMs share the single host-only adapter; the adapter is **not** bridged or NAT-connected, so traffic cannot leave the host. Targets use **synthetic/dummy data only** — never real student data.

7.2 Operations

Operation 1 – verify connectivity between machines:

```
# From the Kali VM, confirm each target is reachable only inside the lab
ping -c 3 192.168.56.20
ping -c 3 192.168.56.30
# Confirm the lab has NO internet route (should fail / be unreachable)
ping -c 2 8.8.8.8   # expected: 100% packet loss
```

Operation 2 – record the lab configuration:

```
# Capture interface and routing state into a dated evidence file
ip addr show > lab_config_$(date +%F).txt
ip route show >> lab_config_$(date +%F).txt
# List the reachable hosts to document the lab inventory
nmap -sn 192.168.56.0/24 >> lab_config_$(date +%F).txt
```

The saved file is the reproducible record of the lab state attached to the engagement.

7.3 Host-only vs NAT – comparison and justification

Factor	Host-only network	NAT network
Internet access from VMs	None (fully isolated)	Outbound internet allowed
Risk of escaping the lab	Very low	Higher — traffic can leave
Inter-VM communication	Yes	Yes
Suitable for exploit testing	**Yes** – containment guaranteed	Risky for live exploits
Updates/tool download	Manual (copy in)	Convenient (direct)

Chosen design: host-only. Justification: containment is the priority. A host-only network guarantees that exploit traffic, malware or a misfired attack cannot reach the internet or the university network, satisfying design criterion C3 (Safe). The only cost — having to copy tools/updates in manually — is a minor, acceptable inconvenience.

7.4 How the lab keeps testing authorized and contained

- Hands-on exploitation is performed **only** against lab targets listed in the RoE, never against live systems.
- The host-only isolation means no action can affect production or external parties.
- Synthetic data removes any DPDP/personal-data exposure during testing.
- The dated config file ties each lab session back to its authorized engagement, keeping the activity traceable (criterion C4).

Task 8 – Reusable Document Library (5 Marks)

Four reusable documents support the framework. Fields with sensible defaults are marked *(default)*.

8.1 Document 1 – Engagement Authorization Form

Field	Example / default
Engagement ID	`ENG-2026-014`
Requesting department	IT Services
Asset owner (approver)	Name + role
Systems authorized	`portal.univ.edu`, `lms.univ.edu`
Testing window	2026-11-20 to 2026-11-22, 22:00–06:00
Permitted techniques	Passive recon, authenticated scan, lab exploitation *(default)*
Signature + date	_____

8.2 Document 2 – Scope / RoE Document

As defined in Task 5 (reused here as a library template).

8.3 Document 3 – Finding Report (produces structured output)

Field	Example
Finding ID	`FND-014-03`
Engagement ID	`ENG-2026-014`
Affected system	`portal.univ.edu`
Vulnerability	SQL injection in login form
Severity (CVSS)	9.1 (Critical)
Evidence	Request/response (no personal data copied)
Recommended fix	Parameterised queries, input validation
Status	Open *(default)*

Structured output (the machine-readable form that integrates with the disclosure layer, Task 6):

```
{
  "finding_id": "FND-014-03",
  "engagement_id": "ENG-2026-014",
  "system": "portal.univ.edu",
  "severity": "Critical",
  "cvss": 9.1,
  "status": "Open",
  "remediation_due": "2026-11-29"
}
```

The `severity` and `remediation_due` fields feed directly into `can_disclose()` and the disclosure timeline.

8.4 Document 4 – Disclosure Log

Field	Example
Finding ID	`FND-014-03`
Reported on	2026-11-22
Acknowledged on	2026-11-22
Remediation due	2026-11-29
Disclosed on	After fix / by agreement
Disclosure type	Coordinated *(default)*

8.5 Test entries – valid, boundary, invalid

Input to Finding Report	Type	Expected result
Valid finding with engagement ID, severity, evidence	**Valid**	Accepted; structured output generated; enters disclosure timeline
Finding with severity present but **no remediation date**	**Boundary**	Accepted with warning; `remediation_due` auto-set from severity default
Finding referencing an **engagement that is not AUTHORIZED**	**Invalid**	Rejected; cannot be reported until engagement is authorized (links to Task 6)
Finding whose system is **out of scope**	**Invalid**	Rejected; flagged as out-of-scope (links to Task 5)

Integration evidence: the Finding Report's structured output is consumed by the authorization–disclosure layer (Task 6), and its validity checks enforce the RoE (Task 5) and authorization rules — demonstrating the documents are reusable components, not isolated forms.

Task 9 – Integrate, Test and Refine the Framework (5 Marks)

9.1 Integrated framework

The components of Tasks 2–8 combine into one engagement pipeline:

```
Request -> Authorization (T6) -> RoE + Scope check (T5)
   -> Legal check (T4) + Threat model (T2) + Ethics rules (T3)
   -> Isolated-lab testing (T7)
   -> Finding Report structured output (T8)
   -> Responsible disclosure (T6) -> Remediation -> Close
```

9.2 Walkthrough of an authorized assessment

1. **Request:** IT Services requests a test of the student portal.

2. **Authorization:** asset owner signs the authorization form; engagement `ENG-2026-014` logged AUTHORIZED (T6).
3. **Scope/RoE:** portal and LMS set in scope; finance DB out of scope; window 22:00–06:00; pre-engagement checklist completed (T5).
4. **Legal/ethics:** portal holds personal data → DPDP + IT Act controls engaged; data-minimisation rule active (T3, T4).
5. **Lab testing:** a copy of the portal app is tested in the host-only lab; SQL-injection flaw found on dummy data (T7).
6. **Report:** Finding `FND-014-03`, CVSS 9.1, structured output generated (T8).
7. **Disclosure:** critical → 24 h acknowledge, 7-day remediation; `can_disclose` withholds detail until fixed (T6).
8. **Close:** fix verified, disclosure log updated, engagement CLOSED.

9.3 Systematic test cases

#	Test case	Framework response	Pass?
T-1	Testing starts with **no signed authorization**	Pre-engagement checklist blocks start; status not AUTHORIZED	✓
T-2	**Out-of-scope** system requested mid-test	Scope rule 5.3 detects, stops, requires amendment	✓
T-3	**Legal conflict** – tester about to copy personal data	Ethics rule 3 + DPDP control stop the action	✓
T-4	**Delayed disclosure** – remediation window passed, no fix	Escalate to CISO; full-disclosure rule 6.4 considered	✓
T-5	Grey-hat student reports a flaw	Routed through disclosure process, not treated as attack (T2)	✓

9.4 Problems found during the walkthrough and refinements

Problem observed	Refinement applied
The first pass had **no explicit owner-verification** step, so a non-owner could approve	Added rule 5.2.2 – approver checked against an owners register
Disclosure could technically start **before** a fix for personal-data findings	Added rule 6.4.3 – never fully disclose personal-data findings pre-fix
Boundary finding with **no remediation date** stalled the timeline	Finding Report now auto-sets `remediation_due` from severity default (T8)
Out-of-scope detection relied on tester judgement	Made it a hard rule (hostname + window + technique) in 5.3

9.5 Final corrected framework

After these refinements the framework satisfies all acceptance criteria C1–C6: every engagement is authorized (C1), legal (C2), lab-contained (C3), logged (C4), scalable (C5) and coordinated in disclosure (C6). The test cases T-1–T-5 all pass against the corrected design, making it reproducible for the next engagement.

Task 10 – Scalability and Governance Evaluation (5 Marks)

10.1 Two scenarios

Scenario	Systems	Testers	Nature
S (small)	5	2 internal	One department
L (large)	120	15 (incl. external)	Whole university + third-party assessors

10.2 Three processes measured

Three framework processes were "run" on paper for each scenario and measured on three indicators — approval turnaround (days), scope coverage (% of systems with a current RoE), and number of manual steps per engagement.

Process / measure	Small (S)	Large (L)
Approval turnaround (days)	1	4
Scope coverage (%)	100%	70%
Manual steps per engagement	8	8
Engagements/month	2	25

10.3 Visualization – small vs large

Structured bar comparison (each block ≈ one unit; longer = higher):

```
Approval turnaround (days)   lower is better
  Small  | #                        1
  Large  | ####                     4

Scope coverage (%)           higher is better
  Small  | ##################### 100
  Large  | ###############       70

Manual steps per engagement  lower is better
  Small  | ########                 8
  Large  | ########                 8
```

10.4 Interpretation

- **Approval turnaround** rises from 1 to 4 days at scale — a single central approver becomes a bottleneck when 15 testers and external parties submit requests.
- **Scope coverage** falls from 100% to 70% — at 120 systems, RoE documents go stale faster than they are renewed, leaving systems without current authorization.
- **Manual steps** stay at 8 regardless of size — the per-engagement process itself scales fine; the problem is **volume and centralisation**, not the steps.

10.5 Governance refinement based on the evidence

The measures drive two concrete governance changes, not just reporting:

1. **Delegated, tiered approval.** Introduce departmental approvers for low-risk engagements, reserving central CISO sign-off for personal-data or external-tester engagements. *Expected effect:* approval turnaround for the large scenario drops back toward 1–2 days by removing the single bottleneck.
2. **RoE expiry and review cycle.** Give each RoE a validity date and an automatic review reminder. *Expected effect:* scope coverage returns toward 100% because stale authorizations are renewed before they lapse.

These refinements keep the framework governable as it grows — directly supporting scalability criterion C5 — and are carried into the changed-requirement defence in Task 11.

Task 11 – Defend the Framework Under a Changed Requirement (5 Marks)

Changed requirement: the university now runs **continuous** and **third-party** assessments, under **stricter data-protection rules** and a **shorter disclosure timeline**, and the framework must stay easy to govern and extend.

11.1 What to retain, modify, replace or redesign

Component	Decision	Reason
Authorization Layer (T6)	**Modify**	Add tiered/delegated approval + per-tester external-assessor vetting
Scope & RoE (T5)	**Retain + modify**	Keep structure; add RoE expiry dates for continuous testing
Legal mapping (T4)	**Modify**	Strengthen DPDP controls; add data-processing agreements for third parties
Threat model (T2)	**Retain**	Still valid; add "external assessor" as an authorized actor subtype
Ethics module (T3)	**Retain**	Principles unchanged; apply equally to external testers
Isolated lab (T7)	**Retain**	Containment model already satisfies stricter data

Component	Decision	Reason
		rules
Disclosure process (T6)	**Modify**	Shorten remediation windows; keep coordinated default
Document library (T8)	**Retain + extend**	Add a third-party NDA/data-processing agreement form

11.2 New/modified component addressing the change

New component – Continuous-Assessment and Third-Party Control (CATC). It adds:

- **Third-party onboarding:** each external assessor signs an NDA + data-processing agreement, is vetted, and is issued scoped, time-limited credentials.
- **Continuous RoE:** standing authorizations with **expiry and auto-review** (from Task 10's refinement) rather than one-off sign-offs.
- **Shortened disclosure SLA:** Critical remediation window cut from 7 days to **72 hours**; High from 15 to **7 days**.

Integration: CATC plugs into the existing Authorization Layer (it issues the credentials the layer logs) and the Disclosure process (it overrides the default timeline table), so the rest of the framework is unchanged — demonstrating the design is extensible, not rebuilt.

11.3 Evidence-based defence

- **From the walkthrough (T9):** the pipeline already enforces authorization → scope → lab → disclosure; adding external testers only changes *who* is authorized, not the flow.
- **From the scalability evaluation (T10):** delegated approval and RoE expiry were already shown to restore turnaround and coverage at scale — exactly what continuous/third-party operation needs.
- **From the legal mapping (T4):** DPDP controls and per-system legal rules are already in place; third-party agreements extend them to external parties.
- **From the disclosure process (T6):** the timeline is parameterised, so shortening windows is a configuration change, not a redesign.

11.4 Remaining trade-offs and future improvements

Trade-off / limitation	Future improvement
Shorter 72-hour windows may strain remediation teams and cause rushed fixes	Add a risk-based exception path with CISO sign-off and interim mitigations
Delegated approval spreads authority and could weaken consistency	Introduce periodic audit of departmental approvers; central dashboard
Manual logging does not scale to continuous assessment	Move to a ticketing/automation system for approvals and disclosure tracking

Trade-off / limitation	Future improvement
External testers increase data-exposure surface	Enforce least-privilege, time-boxed credentials and session monitoring

Conclusion of Task 11: the framework satisfies the changed requirement by **modifying three components and adding one** (CATC) while retaining the rest. Its parameterised disclosure, tiered authorization and contained lab mean continuous, third-party, stricter-data operation is an extension of the existing design — which is the core evidence that the framework is governable and extensible.

Code of Conduct

I Sayed Fazal (192311291) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Sd.fazal Date: 2/11/2026